

Combined US Operations of Banco Santander, S.A.

Technology



Identity and Access Management Standard

TABLE OF CONTENTS

1. INTRODUCTION	3
1.1 PURPOSE OF THIS DOCUMENT	3
1.2 SCOPE AND PERIMETER	3
1.3 DOCUMENT OWNERSHIP, APPROVAL, AND MAINTENANCE	3
2. GOVERNANCE AND ACCOUNTABILITY	4
2.1 STANDARD GOVERNANCE	4
3. ROLES AND RESPONSIBILITIES	5
4. STANDARD	6
4.1 STANDARD OVERVIEW	6
4.2 STANDARD REQUIREMENTS	6
4.2.1 Access Provisioning Requirements	6
4.2.2 Access Change (Mover / Transfer) Management Requirements	10
4.2.3 Ongoing Access Control Requirements	10
4.2.4 Access De-Provisioning (Leavers / Terminations) Requirements	12
4.2.5 Attestation and Certification Requirements	14
4.2.6 Access Logging and Monitoring Requirements	23
4.2.7 Role Management and Separation of Duties (SoD)	25
4.2.8 Access Management Automation Requirements	27
5. REPORTING STRUCTURE AND ESCALATION	28
6. EXCEPTIONS	28
7. DOCUMENT HISTORY AND VERSION CONTROL	29
7.1 OWNERSHIP AND AUTHORSHIP	29
7.2 SIGN OFF	30
7.3 SUBSIDIARY SIGN OFF	30
8. APPENDIX	31
8.1 APPENDIX A – KEY CONTACTS	31
8.2 APPENDIX B – REGULATORY OBLIGATIONS ADDRESSED BY THIS STANDARD	31
8.3 APPENDIX C – GLOSSARY	32
8.4 APPENDIX D – RELATED POLICIES AND PROCESS AND ADMINISTRATIVE DOCUMENTS	34
8.5 APPENDIX E – REQUIREMENTS FOR MANAGER USER ENTITLEMENT REVIEWS	35
8.6 APPENDIX F – RACI MATRIX	36
8.7 APPENDIX G – SLA MATRIX	46

1. INTRODUCTION

1.1 Purpose of this Document

The Identity and Access Management Standard (this “Standard”) establishes the minimum mandatory requirements for governing how user identities are managed and how access to information assets is requested, provisioned, reviewed, and revoked across Combined US Operations of Banco Santander, S.A. (“CUSO”). It applies to all workforce members, applications, systems, platforms, and third-party services that process, store, or transmit CUSO information in on-premises and cloud environments.

This Standard outlines consistent requirements for access lifecycle management, segregation of duties, privileged access, logging, and periodic certification based on risk and regulatory obligations. The objective of this Standard is to ensure that access to information assets is appropriate, timely, auditable, and aligned with least-privilege principles, regulatory expectations, and enterprise risk management objectives.

1.2 Scope and Perimeter

This Standard applies to CUSO, including the business units operating through Santander Holdings USA, Inc. (“SHUSA”) and its subsidiaries (individually, “Subsidiary,” collectively, “Subsidiaries,” and together with SHUSA, “Santander US”) and the Banco Santander, S.A. New York Branch (“BSNY”) first line of defense functional areas within the Technology division. Additional requirements that are specific to an individual Subsidiary can be found in the exceptions section of this Standard. Operating policies and/or standards developed by Subsidiaries must comply with the requirements set forth in this Standard.

This Standard applies to information assets, including those in electronic (e.g., information systems, applications, systems platforms, and computer operations) and physical (e.g., vendor contracts, loan documentation, credit files, signature cards, and personnel information) formats employed in normal operations on the Santander US Public Cloud Landing Zone or on prem environments. This includes information assets processed, transmitted, or stored by third party service providers.

1.3 Document Ownership, Approval, and Maintenance

This Standard is categorized as a CUSO Technology (First Line of Defense) document that is updated and maintained by the CUSO Technology function. This Standard is owned by the Santander US Chief Information Security Officer (“CISO”) and approved by the Santander US Head of Technology and Operations (“T&O”). This Standard is reviewed and endorsed by Subsidiary standard owners.

This Standard is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review.

2. GOVERNANCE AND ACCOUNTABILITY

2.1 Standard Governance

The Santander US CISO will:

- Own and author, review, oversee implementation of, and monitor compliance with the Standard.

The Subsidiary standard owners will:

- Review and endorse this Standard.

The CUSO Technology and Operations Executive Working Group ("T&O EWG") will:

- Review and recommend approval of the Standard to the Santander US Head of T&O.

The Santander US Head of T&O will:

- Approve the Standard.

3. ROLES AND RESPONSIBILITIES

CUSO utilizes a three lines of defense (“LoD”) model for risk management, with separately defined and segregated responsibilities consistent with applicable regulations and guidance.

First Line of Defense – Risk Management

First line of defense (“1LoD”) units have accountability for the primary management of the risks that emanate from their activities. 1LoD units own, identify, measure, control, monitor, and report all risks that are originated through activities such as business origination, the development, marketing or distribution of products, client maintenance, or operational or technological processes supporting customer activity.

Technology is the 1LoD unit accountable for owning, authoring, reviewing, overseeing implementation of, and monitoring compliance with this Standard. Accountabilities of individual functional areas within Technology are defined in Section 4.

Second Line of Defense – Risk Control

The **Risk function** is a second line of defense (“2LoD”) unit that defines risk management frameworks and policies, independently monitors risk exposures, implements comprehensive and appropriate risk controls, and reviews and challenges 1LoD units on their activities to ensure that risk is managed in line with the agreed frameworks and Risk Appetite levels. The Risk function is organized by risk type (e.g., Enterprise Risk Management (“ERM”), Compliance, Credit, Market, Liquidity, Operational, and Model Risk) and other specialized functions (Risk Analytics) at the CUSO and Subsidiary levels. The ERM function administers Risk Governance & Reporting, Material Risk Program, Strategic Risk, Climate Risk, New Product & Business Activities, and Risk Appetite programs. The Second LoD takes primary responsibility for designing and documenting comprehensive enterprise-wide risk management framework that meets regulatory guidelines and is commensurate with the size, complexity, and risk profile of the covered subsidiaries and will be held accountable by the Chief Executive Officer (“CEO”) and the Board.

Third Line of Defense – Risk Assurance

Internal Audit is independent of any other function or unit in CUSO and provides independent assurance to the Board and senior management by assessing the quality and effectiveness of the processes and systems of internal control, risk management and risk governance, compliance with applicable regulations, and the reliability and integrity of financial and operational information.

4. STANDARD

4.1 Standard Overview

This Standard defines the minimum mandatory requirements for the behavior and capabilities in support of IAM. IAM is a capability that supports Technology and Business teams by facilitating and ensuring that the appropriate personnel have access to authorized systems and applications. IAM encompasses the practices, technologies, and teams required to carry out, support, and enforce various functions, including access requests, access provisioning/de-provisioning, access certifications, and access control. Additionally, IAM provides reporting functionality to identify who has access to which systems.

4.2 Standard Requirements

4.2.1 Access Provisioning Requirements

The following requirements and objectives must be addressed for access targets (i.e., information assets that require access control). A matrix has been included in Appendix F to identify the Responsible, Accountable, Consulted, and Informed ("RACI") stakeholders for provision and de-provisioning requirements.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.1.1	s-CISO	Account Management Process The submission, approval, creation, and removal of accounts, entitlements, application roles, and business roles must follow documented processes and procedures with clearly defined roles and responsibilities. - Accounts must receive approval from an authorized approver prior to account creation, initiated from automated process or manual request. - Access requests must explicitly state the entitlements or roles required and may not be modeled after other workforce members. - Each user must receive only one unique account per network, system, or application, except when a separate administrative, privileged, or service account is required. - Each user must receive only one unique account for accessing a Santander US Public Cloud landing zone. - For internal users, Human Resources ("HR") must be the single authoritative source for all internal user account information. - For external users, HR must be the authoritative source for all external user account information.

Requirement ID	Accountable Role / Function	Requirement
		- User account identifiers must be unique and may not contain any personal user details. Personal accounts must be fully synchronized with CUSO HR Systems. - Each account, including non-primary accounts, must be granted to an individual and may not be transferred to or shared with another user. Exceptions to this are required to be accepted as a risk via the risk management methodology. - Individuals requiring administrative or privileged accounts must be assigned a different account from that used for their normal business activities and uniquely assigned to an individual. Additional authentication and monitoring controls referenced in the <i>CUSO Authentication and Authorization Standard</i> must be in place to minimize the potential for unauthorized use. - Administrative accounts and privileged accounts may not have Internet or email access. Privileged Access: Asset administration or configuration activity executed through Privileged accounts. Privileged Account: Any user with permission to create and modify user profiles, or have permission to modify security programs, configurations, or systems settings.
SUS.IAMS.4.2.1.2	s-CISO	Third Parties and Non-employees CUSO must follow a process for third parties to participate, where applicable, in the granting of access for high-risk privileged roles across key applications hosted within Santander US Public Cloud landing zone.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.1.3	s-CISO	Background Checks, Confidentiality Agreements, and Non-Disclosure Agreements (“NDAs”) - Prior to granting access to workforce members who perform security-related functions or who are granted highly privileged access (e.g., system administration, database administration, or administrative (control plane) access to a Santander US Public Cloud landing zone, and change control or supervisor status), a background and reference check must be performed in accordance with established HR processes. - All new hires are required to electronically sign the Acceptable Use Agreement Form, and certain employees may be required to sign NDAs in accordance with established HR processes. - All employees are required to electronically sign the Acceptable Use Agreement Form annually, in line with the <i>CUSO Acceptable Use Standard</i>.
SUS.IAMS.4.2.1.4	s-CISO	On-boarding Procedures As new personnel join the organization, basic access rights entitlements must be granted based on their role.
SUS.IAMS.4.2.1.6	s-CISO	Temporary Access Break glass access must be approved by s-CISO or Chief Information Officer (“CIO”) Infrastructure or delegate through a ticket request or incident ticket. Break glass activity must be monitored. Access must be removed when it is no longer needed.
SUS.IAMS.4.2.1.7	s-CISO	Remote Access - Remote access to the CUSO network must be end to end secured using an approved Virtual Private Network (“VPN”). - Remote access must use multi-factor authentication, (e.g., Microsoft Authenticator). Remote access must be terminated within 24 hours after the user is terminated or determined to no longer have a compelling business justification for remote access. Refer to the <i>CUSO Network Security Standard</i> for additional remote access requirements.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.1.10	s-CISO	Service Accounts The password of the account must be rotated regularly and must be custody through the approved Privileged Access Management System ("PAMS"). If a PAMS for storing service ID passwords is not in place or rotation is not feasible, password must have additional complexity requirements validated by the s-CISO (e.g., 16 randomly generated characters meeting complexity requirements, password dictionary control, etc.) so the password does not expire.
SUS.IAMS.4.2.1.11	s-CISO	Service accounts created in the Santander public cloud must authenticate to other service accounts in the same Santander LZ and authorized using Amazon Web Services ("AWS") native IAM roles via AWS Security Token Service ("STS"), OpenID Connect ("OIDC"), or mTLS.
SUS.IAMS.4.2.1.12	s-CISO	Service accounts created on-prem must be authenticated and authorized to service accounts in a Santander LZ using Roles anywhere, OIDC, or mTLS.
SUS.IAMS.4.2.1.13	s-CISO	Service accounts which authenticate to third parties, must authenticate using OIDC tokens with an approved Santander IdP (e.g., EntraID) or use AWS native IAM roles with AWS STS or mTLS.
SUS.IAMS.4.2.1.14	s-CISO	Service accounts created on-prem with local secrets (Static Application Programming Interface ("API") Keys) must only be used as exception and will require express approval of the head of IAM. These accounts will require additional controls and operational restrictions as defined by the IAM Cloud team (e.g., creation via SailPoint, password rotation requirements, and conditional access like IP whitelisting, Virtual Private Cloud Identifier ("VPCID"), etc)

4.2.2 Access Change (Mover / Transfer) Management Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.2.1	s-CISO	Updates to Access Rights - Each manager must be responsible for the entitlements of workforce members under his/her control and for updating the HR system of each workforce member's transfer, which initiates an automated process. - Additional access rights entitlements must be provisioned only when requested separately by an Access Requester, which is initiated by an automated process, validated by the proper supervisor, and authorized by the Application Business Owner. - All access rights for movers must be recertified per Service Level Agreement ("SLA") within 30 business days of their new assignment date. - For workforce members transferring between the Santander Group companies, any privileged accesses of these users must be disabled within a maximum period of three (3) working days. If an exception to this timeline is required, it must be approved through the Security Exception Function ("SEF").
SUS.IAMS.4.2.2.2	s-CISO	Reporting of Movers - Managers (or approved delegates) must report any movers for external and internal movers to the User System of Record. - HR must report any movers for external and internal movers to the Information Security team via the HR System.

4.2.3 Ongoing Access Control Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.3.1	s-CISO	Inactive Accounts User Active Directory accounts unused for the previous 90 calendar days must be reviewed for inactivity and, if confirmed to be inactive, disabled or removed.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.3.2	s-CISO	Documentation, Segregation, and Maintaining Up-to-Date Users All certified access rights must be documented and current. Technology Platform Owners must identify users whose access rights violate the Separation of Duty ("SoD") rules and be reviewed with managers/supervisors. Any exceptions must be documented, risk-assessed, and formally approved within 30 business days of the management review.
SUS.IAMS.4.2.3.3	s-CISO	Modifications or additions to user access permissions must trigger automated notifications to user's manager.
SUS.IAMS.4.2.3.4	s-CISO	Privileged Access Change - Access rights must be provisioned only when requested by an Access Requestor via an approved request mechanism, validated by the proper manager, and authorized by a second level approver. - Technology Platform Owners must only authorize access rights adhering to the "minimum required privilege" principle and SoD rules. - The use of an approved mechanism is required to confirm that the request and approval is fully documented for auditing purposes.
SUS.IAMS.4.2.3.5	s-CISO	Privileged Access Change Formalization Managers (or approved delegates) must inform HR of any changes in functional roles of internal privileged users within 90 calendar days or the next certification cycle.
SUS.IAMS.4.2.3.6	s-CISO	Application Information/Ownership/Administration Change Formalization The Application Owners and Administrators (or approved delegates) must inform their corresponding Application IT stewards of any changes in the ownership, administration to be updated in Mega and its information in SanIAM to SanIAM team within 90 calendar days or prior to the next certification cycle.
SUS.IAMS.4.2.3.7	s-CISO	All human access to the operating system level on any compute service in the public cloud environment must be performed exclusively through an approved session manager.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.3.8	s-CISO	There must be no nominal user account with privileged access rights on servers or databases. Any privileged user rights changes must be performed through PAMS.
SUS.IAMS.4.2.3.9	s-CISO	Trained database administrators must monitor databases and maintain general awareness of normal operations, complementing the Information Security function. Users must be limited to only the data and information appropriate to their granted levels of access. Management must closely monitor database administrator activities as both a preventive and detective control, including access administration and data alterations.

4.2.4 Access De-Provisioning (Leavers / Terminations) Requirements

The following requirements and objectives must be addressed for access targets (information assets that require access control). A RACI matrix has been included in Appendix F to identify the Responsible, Accountable, Consulted, and Informed stakeholders for provisioning and de-provisioning requirements.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.4.1	Managers	Reporting of Leavers Privileged Access change reporting to HR - Managers (or approved delegates) must immediately report any external and internal leavers to HR. - HR must immediately report any external and internal leavers to the Information Security team.
SUS.IAMS.4.2.4.2	IAM team	Revocation of Network ID Access for Terminated Users - Network Access for terminated users must be in line with the SLAs defined in the SLA matrix located in Appendix G. - If the SLA is missed, a look-back assessment must be completed to determine if entitlements were used beyond the termination date.



Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.4.3	IAM/PAM Team	Privileged Access Revocation - Privileged access and control plane access for terminated users must be in line with the SLAs defined in the SLA matrix located in Appendix G. - If appropriate when the SLA is missed, initiate a look-back assessment must be completed to determine if entitlements were used beyond the termination date.

4.2.5 Attestation and Certification Requirements

This Standard describes the types of access reviews that must be performed periodically.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.1	IAM / PAM Team	The recertification process must be performed as a formal review of information assets to confirm that all granted access rights entitlements remain valid, updated, and in full compliance with the SoD rules and Principle of Least Privilege.
SUS.IAMS.4.2.5.2	IAM / PAM Team	Execution of a recertification for information assets and collecting all recertification evidence that access rights entitlements have been validated within SLAs (refer to Appendix G for additional information).
SUS.IAMS.4.2.5.3	IAM / PAM Team	Identification of users whose access rights entitlements violate the SoD rules and review with supervisors. Any violations must be either remediated or documented, risk-assessed, and formally approved within SLAs (Refer to Appendix G for additional information).

The following table summarizes the reviews described in this Standard and their minimum required frequencies. The s-CISO must track completion status within the SLAs and escalate any undue delays.

Access Review Type	Description	Who Performs	Minimum Frequency
Application Certification	Review general application details	Application Business Owner	Annually for centrally managed applications
Application Owner User Entitlement Review ("UER")	Attest to access rights of all uncorrelated accounts	Application IT Owner	Case by case
Default Privileged Roles Certification	Review the access rights associated with default privileged roles and verify that they match the definition and adhere to "minimum required privilege" for applications, operating systems, databases, and network devices.	Application IT Owner	Annually
Manager UER	Attest to access rights of direct reports	Manager	See UER requirements below

Access Review Type	Description	Who Performs	Minimum Frequency
Privileged Access Review ("PAR")	Attest to access rights for privileged users for applications, operating systems, databases, and network devices	Application IT Owner	See PAR requirements below

User Entitlement Reviews

This section specifies the UER requirements for applications in-scope for this Standard. A RACI matrix has been included in to identify the Responsible, Accountable, Consulted, and Informed stakeholders for UER requirements.

Requirement ID	Accountable Role / Function	Requirement			
SUS.IAMS.4.2.5.4	s-CISO	Manager UER Minimum Frequency by Application Inherent Risk			
		Use the table below to determine Manager UER Minimum Frequency by Application Inherent Risk.			
		Application Inherent Risk	Application Type		
			SOX	Gramm-Leach-Bliley (“GLBA”)	Other
			Critical	Semi-Annual	Annual
		High	Annual		
		Moderate	Annual		
		Low	Management Discretion		
Very Low	<u>Management Discretion</u>				
Any business or end user applications registered in MEGA:					
• In production where deployment scope is US based • With active users • Not covered through birthright access • Sarbanes-Oxley Act (“SOX”), Gramm-Leach-Bliley Act (“GLBA”), Critical or High IRA or Moderate and below with a Restricted Confidential or Secret data classification					

Requirement ID	Accountable Role / Function	Requirement
		Must be considered in scope for central management as per SLA in this document. - SOX, GLBA, Critical IRA, High IRA rated applications or those with a data classification of Secret or Restricted Confidential must be onboarded into the Identity and Access Management System ("IAMS"). - SOX, GLBA, Critical IRA, High IRA rated applications or those with a data classification of Secret or Restricted Confidential with an approved exception for the IAMS must be onboarded into the Identity Management Portal ("IMP"). The criteria for onboarding exceptions are technical limitations, SoD limitations, environment limitations, decommissioning or a user base less than two (2) users. Using a risk-based approach, File Shares containing Non-Public Personal Information ("NPPI") must be certified semi-annually. Using a risk-based approach, Unstructured Data Locations containing NPPI must be certified annually.
SUS.IAMS.4.2.5.5	s-CISO	UER Responsible Personnel Both managers and Application Owners must perform UERs for applications in the IAMS.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.6	Manager and Application Owner	Manager and Application Owner UER Requirements for applications in the IAMS Managers must be responsible for attesting to the entitlements and roles assigned to their direct employees, contractors, and other workforce members. Application Owners must be responsible for attesting to the entitlements of vendor, system, and uncorrelated accounts. At a minimum, the following schedule must be adhered to for performing user access recertification: • All applications with an inherent risk of Critical or High must be recertified annually at minimum. • All SOX applications must be recertified on a minimum semi-annual basis. • All GLBA applications must be recertified on a minimum annual basis. • Any access rights on restricted information assets must be recertified semi-annually. • Any access rights on confidential information must be recertified semi-annually. • Access rights for users with non-read-only access (insert, modify, or delete) for internal and public information must be recertified annually. • Any accounts assigned to external users must be recertified at least semi-annually. • User access to privileged accounts enrolled in PAMS must be recertified quarterly. • All other applications not meeting one or more of the above criteria must be recertified on an as-needed basis. As necessary, this action may be performed by a higher-level manager or the organization's security representative.
SUS.IAMS.4.2.5.22	Application Owner	Application Owners must be responsible for registering, evidencing, and attesting to the entitlements of accounts in the IMP and must be conducted annually.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.7	s-CISO	UER Outcomes for IAMS For both types of UERs, one of the following actions must be performed based on the review results: - Request removal of business role(s), application role(s), or entitlement(s) assigned to the user. Access is denied if <i>any</i> of the minimum required reviewers (workforce member's management, organization security representative, or Application Owner) deny access to a workforce member. - Approve existing entitlements assigned to the user. Any revocations of access rights must be completed within 30 business days per the SLA.
SUS.IAMS.4.2.5.8	s-CISO	Baseline UER Process Requirements for Process Owners Owners of the UER process must confirm that the process adheres to the following requirements: - Each process task (i.e., manager review or de-provisioning) must have a maximum allowed duration and an escalation process defined - Where possible, an attestation and certification service must be used instead of manual methods that rely upon ad-hoc reports and reviews. The attestation and certification service requires periodic feeds, daily or weekly where feasible, detailing current access target accounts, entitlements, and roles Each system or service account must be the responsibility of one workforce member.

Privileged Access Review

Privileged Access: Users with elevated privileges, as required for system, network, application, and/or database administration and not generally meant for day-to-day business use. Privileged accounts include “super users,” service accounts, local administration accounts, emergency accounts, and application-specific administrative accounts.

Identification of privileged accounts must be carried out in consultation with Technology Platform Owners, Application Owners, Business, and Technology Infrastructure teams. In the instance of business application privileged access, the Application Owner must be considered the Technology Platform Owner for identifying roles and responsibilities pertaining to privileged access, as laid out in this Standard.

Requirement ID	Accountable Role / Function	Requirement												
SUS.IAMS.4.2.5.9	Manager or Asset / account Owner	Review of Privileged Access Review of privileged access and control plane must conform to the following requirements: <table><tr><th>Information Asset / Account Type</th><th>Description</th><th>Who Performs</th><th>Minimum Frequency</th></tr><tr><td>All information assets</td><td>Attest to access rights for all privileged users of the asset</td><td>Manager or asset / account owner</td><td>Semi-Annual</td></tr><tr><td>Privileged access certification for accounts assigned to external users</td><td>Attest to access rights for external users with privileged accounts</td><td>Manager or asset / account owner</td><td>Semi-Annual</td></tr></table> Refer to the <i>CUSO Data and Information Protection Standard</i> for data classification requirements satisfactory.	Information Asset / Account Type	Description	Who Performs	Minimum Frequency	All information assets	Attest to access rights for all privileged users of the asset	Manager or asset / account owner	Semi-Annual	Privileged access certification for accounts assigned to external users	Attest to access rights for external users with privileged accounts	Manager or asset / account owner	Semi-Annual
Information Asset / Account Type	Description	Who Performs	Minimum Frequency											
All information assets	Attest to access rights for all privileged users of the asset	Manager or asset / account owner	Semi-Annual											
Privileged access certification for accounts assigned to external users	Attest to access rights for external users with privileged accounts	Manager or asset / account owner	Semi-Annual											
SUS.IAMS.4.2.5.10	s-CISO	Reviewing Privileges for Infrastructure Components for on prem and Administrative Detailed review processes with roles and responsibilities must be identified and followed for applications, operating systems, databases, and network devices. These processes must include: - Review and confirmation of the population in scope for the recertification. - Comparisons of compiled access data against final outputs from each platform to confirm data completeness. - Review of script outputs to confirm that all access marked for removal was removed. All privileged access generic accounts must be assigned to a supervisor responsible for controlling all the users with access permission to these accounts. The user behind each access must be identified. All control plane generic accounts must be assigned to a supervisor responsible for controlling all the users with access permission to these accounts and reviewing them periodically.												

Application Certification Requirements

This section describes the application certification requirements for applications in scope of this standard. A RACI matrix has been included in Appendix F to identify the Responsible, Accountable, Consulted, and Informed stakeholders for application certification requirements.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.11	s-CISO	Application Certification Frequency For applications managed with a centralized attestation and certification tool, application certifications must be conducted in accordance with the required frequency identified in Section 4.2.5 to confirm that application data is accurately maintained.
SUS.IAMS.4.2.5.12	Application Owner	Application coverage for non-person accounts Associated service accounts must be maintained.
SUS.IAMS.4.2.5.13	Application Owner	Pre-Certification Validation Accuracy and general business understandability must be reviewed and updated for the following elements: • Application name • Application description • Entitlement names • Entitlement business descriptions
SUS.IAMS.4.2.5.14	s-CISO	Names and Business Description Requirements The application, associated entitlements, and service accounts must be evaluated to help confirm that names and business descriptions accurately and succinctly convey the information required by the reviewer (especially risk information) to review and certify the access.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.15	s-CISO	Application Certification Outcomes One or more of the following actions must be performed based on the review of the application and entitlement names and descriptions: • Request for an application and/or entitlement name change • Request for a change to the description • Request for a change to the entitlement and/or application role risk scores • Request for a change to decommission an entitlement, service account, or application role. The decommissioning of an application role must not impact existing audit logging or the ability to review how the application role was used before its removal • If the application, entitlements, roles, and risk scores are accurate, the Application Owner must approve Application Owners must perform the certification process annually or as required by the IAM team.

Default Privileged Roles Certification

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.16	IAM / PAM Team	Overall Objectives and Responsibilities The privileged access review and default roles recertification processes are a regular formal review of every information asset to confirm that all granted access rights remain valid, updated, and in full compliance with SoD rules and the Principle of Minimum Required Privilege. IAM/PAM Team are accountable for executing and collecting all evidence that access rights have been validated.
SUS.IAMS.4.2.5.17	IAM / PAM Team	Default Access Review Minimum Frequency The IAM team must review that default access rights associated with default privileged and control plane access roles match the definition and adhere to “minimum required privilege” at least annually.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.5.18	Managers / Application owners	Documentation, Segregation, and Maintaining Up-to-Date Users All certified access rights must be documented, and Managers/applications owners must review users whose access rights violate SoD rules. Any exceptions must be documented, risk-assessed, and formally approved within 30 business days from the management review.
SUS.IAMS.4.2.5.19	IAM / PAM Team	Minimum Recertification for Privileged Access on All Assets Execution of the recertification process must occur at least semi-annually for privileged access rights on any asset.
SUS.IAMS.4.2.5.20	s-CISO	Default System Account Controls Default system IDs are appropriately restricted by locking the accounts, removing the accounts, changing the default passwords, or configuring the accounts to prohibit interactive login, as appropriate. For IDs which can't be changed, exceptions must be documented, risk-assessed, and formally approved within 30 business days.
SUS.IAMS.4.2.5.21	IAM / PAM Team	Privileged Access Review Process IAM / PAM Team must perform the process per the frequencies defined in Section 4.2.5 of this Standard. Any revocation of privileged access rights resulting from the privileged access review outcomes must be completed within 30 business days of the close of the review per the SLA.

4.2.6 Access Logging and Monitoring Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.6.1	s-CISO	General Access Logging The following must be logged and kept for future audit: • Account creation, removal, and changes to when an account can be used (time of day usage and account expiration), including approvals where applicable. • Password reset attempts. • Entitlement, business role, and application role additions/changes/removals to an account. The <i>CUSO Security Logging and Monitoring Standard</i> must be referred to confirm that all applicable requirements related to access audit trail content, security access events, and user access reviews are addressed.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.6.2	s-CISO	Privileged Access Logging • All privileged account access and control plane access and activity must be logged and stored per retention schedules mandated by the <i>CUSO Security Logging and Monitoring Standard</i> and protected against unauthorized modification. • A minimum set of alerts on privileged account activity and control plane account activity must be defined as online controls of privileged access activity must be defined as online controls of control plane access activity. These alerts must be operational and monitored 24x7 and must include at minimum the following aspects: ○ Login conditions: Relevant number of consecutive failed authentication, geographical, and workhours compatibility with user location, and frequency. ○ Access to critical functions: Audit process deactivation, additional privileges granting, and new privileged user creation. ○ All usage of APIs executed within the control plane must be logged including the user account which invoked the API. ○ Deviation from expected access patterns: Access to new infrastructure elements and execution of previously unused commands. The <i>CUSO Security Logging and Monitoring Standard</i> must be referred to confirm that all applicable requirements related to access audit trail content, security access events, and user access reviews are addressed.

4.2.7 Role Management and Separation of Duties (SoD)

This section specifies the role management requirements for applications in-scope of this Standard. A RACI matrix has been included in Appendix F to identify the Responsible, Accountable, Consulted, and Informed stakeholders for role management and SoD requirements.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.7.1	s-CISO	Managing Complex Entitlements Combining multiple entitlements into a role that can be used to simplify the access request, access provisioning, and access attestation processes must be considered for applications with complex entitlements.
SUS.IAMS.4.2.7.2	s-CISO	Role Management Process A process for designing, implementing, assigning, and reviewing roles and associated entitlements and SoD must be developed when roles are used. This process must confirm that: • Roles are designed to maintain least privileged access • Entitlements do not violate SoD rules • Every role has an identified role owner who is accountable for the role and access contained within • Every role has an up-to-date business-facing explanation of the role, its entitlements, and risks Role development is focused on well-defined and stable positions within the organization, where the benefits of managing the role out-weigh the effort and cost to maintain the role.
SUS.IAMS.4.2.7.3	s-CISO	Role Certification CUSO must implement a process where role owners certify, on at least an annual basis, the correctness of entitlements assigned to a role (for both application and business roles). Furthermore, CUSO must implement a process where managers, on at least an annual basis, certify or attest that their direct reports have the correct roles to perform their job functions.

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.7.4	s-CISO	Business Risk Identification Business (and/or operational) risks associated with roles / entitlement combinations must be identified as part of the role management process for business applications. Business and risk management teams must be consulted as part of the role design / review process to take into account the business (and/or operational) risks associated with the roles / entitlement combinations. Details of high-risk roles / entitlement combinations must be developed, regularly reviewed, and signed off on by business and risk management teams.
SUS.IAMS.4.2.7.5	s-CISO	Policy Violation (SoD and Toxic Combination) Requirements • Application Business Owners must identify and document SoDs where conflicting duties create the opportunity for users to commit fraud within an application. • Application Business Owners must identify and document toxic combinations where conflicting duties across different information assets create the opportunity for users to commit fraud. • Technology Platform Owners must identify all potential Policy Violation conflicts within their information assets. • Technology Platform Owners and the IAM team, with the support of all concerned Business areas, must identify processes with potential Policy Violation conflicts across different information assets. • Policy Violations (SoDs and Toxic Combinations) must be coded in the Identity and Access Management System ("IAMS"). • Provisioning and authorization must incorporate Policy Violation requirements to confirm that conflicting entitlements or roles either within one single application or across different information assets are not granted unless approved by the Technology Platform Owner. • Technology Platform Owners, the IAM team, and Business Areas must review Policy Violation rules at least annually.
SUS.IAMS.4.2.7.6	s-CISO	In the Santander US Public Cloud landing zone, role owners must certify, on at least an annual basis, the correctness of entitlements assigned to a role (for both application and business roles).

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.7.7	s-CISO	In the Santander US Public Cloud landing zone, access to development, test, pre-production, and production must be segregated.

4.2.8 Access Management Automation Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.IAMS.4.2.8.1	s-CISO	Using a risk-based approach, information assets must be integrated with an IAMS approved by the s-CISO for the processes of identification, authentication, provisioning, and de-provisioning of user access rights entitlements.
SUS.IAMS.4.2.8.2	s-CISO	All privileged account to information assets must be integrated with a PAMS for the purposes of authentication of privileged user and sign-off on infrastructure assets. In the Santander US Public Cloud landing zone, all administrative (control plane) roles and entitlements must be integrated with an approved session management system for the purpose of authentication.
SUS.IAMS.4.2.8.3	s-CISO	All privileged accesses must comply with IAM requirements regardless of their level of integration with the PAMS. For non-integrated assets, the Application Business Owner must define a plan to complete PAM integration.

5. REPORTING STRUCTURE AND ESCALATION

As part of an overarching risk assessment and reporting program, CUSO must conduct regular self-assessments to measure design adequacy and operating effectiveness of controls specified in this Standard. The results must be incorporated into risk reporting provided to the CUSO 2LoD functions, and to the Board, if applicable, in accordance with 2LoD function’s governance requirements.

6. EXCEPTIONS

Standard exceptions are expected to be infrequent but may be granted to address specific business needs. Subsidiary-specific exceptions require review and approval from both the s-CISO and the Santander US CISO. All approved Subsidiary-specific exemptions are listed in the table below.

Any additional material exceptions not explicitly defined in this section must include documented rationale, an assessment of associated risks (where applicable), and any other relevant details. These exceptions must be reviewed and approved during the SEF meeting.

Subsidiary:	Exceptions:
There are no subsidiary exceptions to the scope of this standard.	

7. DOCUMENT HISTORY AND VERSION CONTROL

7.1 Ownership and Authorship

Version	Author	Owner	Change
1.0	Santander US Information Risk Management ("IRM")	Santander US Chief Information Risk Officer	Initial version
2.0	Santander US Information Security	Santander US CISO	Annual update
3.0	Santander US Information Security	Santander US CISO	Refresh based on updated IRM Taxonomy
3.1	Santander US Information Security	Santander US CISO	Update to Manager UER Frequency
4.0	Santander US Information Security	Santander US CISO	2019 Annual update
4.1	Santander US Information Security	Santander US CISO	2020 Annual update
5.0	Santander US Information Security	Santander US CISO	2021 Annual update
6.0	Santander US Information Security	Santander US CISO	2022 Annual update
7.0	Santander US Information Security	Santander US CISO	2023 Off Cycle Update
7.1	Santander US Information Security	Santander US CISO	2023 Off Cycle Update – Non-Material Change
8.0	Santander US Information Security	Santander US CISO	2023 Annual Update
8.1	Santander US Information Security	Santander US CISO	2024 Off Cycle Updates - DORA related updates
9.0	Santander US Information Security	Santander US CISO	2024 Annual Update

Version	Author	Owner	Change
10.0	Santander US Information Security	Santander US CISO	2025 Off Cycle updates to align with cybersecurity group policies.
11.0	CUSO Information Security	Santander US CISO	2025 Annual Update

7.2 Sign Off

Approver	Action	Date
Santander US Head of T&O	Approve	07/28/2026

7.3 Subsidiary Sign Off

Approving Body	Governance Committee Approval or Endorsement	Final Approval Date
Santander US CISO	Endorsement	07/22/2026
SBNA CISO	Endorsement	04/30/2026
Santander US Auto CIO	Endorsement	07/21/2026
BSI CIO	Endorsement	07/23/2026
Santander US Corporate and Investment Banking ("CIB") CIO	Endorsement	07/28/2026

8. APPENDIX

8.1 Appendix A – Key Contacts

Title	Role	Name and Contact
Santander US Head of T&O	CUSO Technology	Patryk Nowakowski (patryk.nowakowski@santander.us)
Santander US CISO	CUSO Information Security	Alberto Hernandez (Alberto.Hernandez@santander.us)
Sr. Director, Information Security	CUSO Information Security	Robert Burden (robert.burden@santander.us)
SBNA CISO	CUSO Information Security	Andre Salgado (andre.salgado@santander.us)
Santander US Auto CIO	CUSO Technology	Bobby Mehra (bobby.mehra@sanatnder.com)
SC CISO	CUSO Information Security	Rebecca Smith (rebecca.smith@santander.us)
BSI CIO	Banco Santander International Technology	Jose Oliveros (joliveros@bpi-gruposantander.com)
Sr. Director, Information Security	Banco Santander International Technology	Dayam Borges (dborges@bpi-gruposantander.com)
Santander US CIB CIO	CUSO Capital Markets, LLC/Banco Santander New York Technology	Xavier Jean Courtois (xavier.courtois@santander.us)
CIB Chief Information Security Officer	CUSO Capital Markets LLC/Banco Santander New York Technology	Frank Hsieh (frank.hsieh@santander.us)

8.2 Appendix B – Regulatory Obligations Addressed by this Standard

The following are the primary regulations addressed by CUSO Technology Standards:

- GLBA 501(b) - Interagency Guidelines Establishing Standards for Safeguarding Customer Information
- GLBA 501(b) - Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice

In addition, CUSO considered the following supervisory sources in developing Standards and in its ongoing assessment and oversight of risk:

- Federal Financial institutions Examination Council (“FFIEC”) IT Handbook, including:
 - Information Security Booklet
 - Development and Acquisition Booklet
 - Architecture, Infrastructure, and Operations Booklet
 - Management Booklet
 - Outsourcing Technology Booklet
 - Supervision of Technology Service Providers Booklet
 - Business Continuity Management Booklet
- Office of the Comptroller of the Currency (“OCC”) Model Risk Management booklet of the Comptroller's Handbook
- US Securities and Exchange Commission 2017-02 Guidance Update (Robo Advisers)
- National Institute of Standards and Technology (“NIST”) Artificial Intelligence Risk Management Framework (AI RMF 1.0)
- International Standards Organization (“ISO”) ISO/IEC 38507:2022 Information Technology — Governance of IT — Governance implications of the use of Artificial Intelligence by organizations
- The National Cyber Security Centre (“NCSC”) Guidelines
- Personal Data Protection Commission Singapore (“PDPC”) Model
- Monetary Authority of Singapore

8.3 Appendix C – Glossary

Term	Definition
Application Administrator	The individual responsible for the operation of the application. Operational tasks include but are not limited to the execution and evidence retention of security, performance, availability, operational compliance, incident, change and release, and configuration tasks. This will include roles defined as the Application Access Administrator (currently IAM Administrator in MEGA) on the IAM solutions in use at CUSO.
Application Owner	The individual accountable for the lifecycle and operation of an application in support of a business process. This will include roles defined as the Application Access Owner (currently IAM Owner in MEGA) on the IAM solutions in use at CUSO.
Basic Access Right	A basic access right is a group of birthright roles that are granted to an individual based on their assigned role and job profile. It is a standard set of entitlements defined as required for each role to complete their job responsibilities.
Business Assets	These are information assets where business data and processes are managed (business applications, information services). These assets are inventoried in the official application portfolio repository tool (e.g. APM).
Business Process Owner	The individual accountable for the lifecycle and execution of a business process.
Business Role	A collection of permissions based upon a role within an organization. A business role is a collection of one or more entitlements.

Term	Definition
Entitlement	A collection of one or more permissions.
Identity and Access Management Team	The team within Information Security that is responsible for managing and maintaining operation of the IAM program.
Information Owner	The individual accountable for the data involved in one or more applications and/or IT Systems.
Information Security	The function responsible for execution of the CUSO Information Security program and operational processes.
Infrastructure Assets	These are information assets supporting business assets or dedicated infrastructure elements. These assets are inventoried in the official infrastructure repository tool (e.g. CMDB).
HR	The function responsible for developing and executing HR strategies, employment policies, and compensation programs.
IRM	The IRM function reviews aggregate Information Risks at an enterprise level through the use of control frameworks, metrics, and independent risk assessments. IRM evaluates conformance to the IRM framework by monitoring how the first LoD identifies and manages risk, supported by policies and standards that enable sustainable governance that drive mitigation, prioritization, and action.
Manager / Supervisor	The person to whom a workforce member directly reports.
PAMS	Privilege Access Management System (e.g. CyberArk)
Role Owner	The individual assigned responsibility for maintaining the entitlements assigned to a role. The role owner must be assigned this responsibility after approval or under delegation from the Application Owner.
s-CISO	The executive responsible for managing the Information Security function at a specific subsidiary.
Santander US CISO	The executive accountable for managing the Information Security function at CUSO.
Technology Platform Owner	A technical owner assigned to ensure the accuracy of inventory and configuration information for a given class of assets.

Term	Definition
User Risk	User risk is defined as the ongoing assessment of the likelihood that a user's identity or account has been compromised. Risk signals include: leaked/breached credentials detected via threat intelligence, anomalous user behavior patterns, impossible travel detections, and indicators from Microsoft Entra ID Protection or equivalent. User risk levels (low, medium, high) are fed into conditional access policies to enforce password changes, MFA challenges, or access blocking as appropriate.
Workforce Members	Employees, contractors, vendors, volunteers, trainees, and other persons whose conduct is under the control of CUSO in the performance of work for the benefit of CUSO.

8.4 Appendix D – Related Policies and Process and Administrative Documents

Document Type	Subsidiary / Department	Owner	Title
Policy	CUSO Operational Risk Management	Santander US Chief Operational Risk Officer	CUSO Information Risk Management Enterprise Policy
Policy	CUSO Technology	Santander US CISO	CUSO Information Security Operating Policy
Standard	CUSO Technology	Santander US CISO	CUSO Authentication and Authorization Standard
Standard	CUSO Technology	Santander US CISO	CUSO Security Logging and Monitoring Standard
Standard	CUSO Technology	Santander US CISO	CUSO Data and Information Protection Standard

8.5 Appendix E – Requirements for Manager User Entitlement Reviews

Manager User Entitlement Review (UER)				
Regulatory/ Non-Regulatory	Type	Application Inherent Risk	Minimum Frequency	Reference
Regulatory / Non-Regulatory	File shares and unstructured data location	N/A	Semi Annual	4.2.5
Regulatory	SOX	Critical	Semi Annual	4.2.5
		High	Semi Annual	4.2.5
		Moderate	Semi Annual	4.2.5
		Low-	Semi Annual	4.2.5
		Very Low	Semi Annual	4.2.5
	GLBA	Critical	Annual	4.2.5
		High	Annual	4.2.5
		Moderate	Annual	4.2.5
		Low-	Annual	4.2.5
		Very Low	Annual	4.2.5
Non-Regulatory	Other	Critical	Management Discretion	4.2.5
		High	Management Discretion	4.2.5
		Moderate	Management Discretion	4.2.5
		Low	Management Discretion	4.2.5
		Very Low	Management Discretion	4.2.5

8.6 Appendix F – RACI Matrix

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
Access Provisioning Requirements	SUS.IAMS.4.2.1.1	Account Management Process	R	R	R	A/R		I	I	C
		Third Parties and Non-Employees	R	R	C	A		I	I	I
	SUS.IAMS.4.2.1.3	Background Checks, Confidentiality Agreements, and Non-Disclosure Agreements (“NDAs”)	I				A/R			I
	SUS.IAMS.4.2.1.4	On-boarding Procedures	I				A/R			I
	SUS.IAMS.4.2.1.6	Temporary Access	R	R	R	A		A/R	C	I
	SUS.IAMS.4.2.1.7	Remote Access	R	R	R	A		R	C	I
Service Accounts	SUS.IAMS.4.2.1.10	Service Account Passwords	R	R	R	A/R			I	C
	SUS.IAMS.4.2.1.11	Service accounts created in the Santander public cloud	R	R	R	A/R			I	C

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
	SUS.IAMS.4.2.1.12	Service accounts created on-prem.	R	R	R	A/R			I	C
	SUS.IAMS.4.2.1.13	Service accounts which authenticate to third parties	R	R	R	A/R			I	C
	SUS.IAMS.4.2.1.14	Service accounts created on-prem with local secrets (Static API Keys)	R	R	R	A/R			I	C
Ongoing Access Control	SUS.IAMS.4.2.3.3	Privileged Access Change Intimation	R	C	C	A		R	A	C
	SUS.IAMS.4.2.3.4	Privileged Access Change	R	R	R	A		R	C	C
	SUS.IAMS.4.2.3.5	Privileged Access Change Formalization	C	C	C			A/R	C	

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
	SUS.IAMS.4.2.3.6	Application Information/Ownership/Administration Change Formalization	R	I	A	R		C	C	C
	SUS.IAMS.4.2.3.7	All human access to the operating system level on any compute service in the public cloud environment must be performed exclusively through an approved session manager.	R	A	A	I		I	C	I
	SUS.IAMS.4.2.3.8	There must be no nominal user account with privileged access rights. Any privileged user rights changes must be performed through PAMs. If this is not possible, an exception must be documented and approved by SEF annually.	C					R	A/R	
	SUS.IAMS.4.2.3.9	Trained database administrators must monitor databases and maintain general awareness of normal operations, complementing the Information Security function.						R	A/R	



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
		Users must be limited to only the data and information appropriate to their granted levels of access. Management must closely monitor database administrator activities as both a preventive and detective control, including access administration and data alterations.								
Access De-Provisioning (Leavers / Terminations) Requirements	SUS.IAMS.4.2.4.1	Reporting of Leavers Privileged Access change reporting to HR	C	C	C	C	A/R	A/R	I	I
	SUS.IAMS.4.2.4.2	Revocation of Network ID Access for Terminated Users	R	C	R	R		A	C	
	SUS.IAMS.4.2.4.3	Privileged Access Revocation	R	C	R	R		A	C	



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
Attestation and Certification Requirements	SUS.IAMS.4.2.5.1	The recertification process must be performed as a formal review of information assets to confirm that all granted access rights entitlements remain valid, updated, and in full compliance with the SoD rules and Principle of Least Privilege	R	I	A	R		A/R	I	I
	SUS.IAMS.4.2.5.2	Technology Platform Owners must be held accountable for executing the recertification for their information assets and collecting all recertification evidence that access rights entitlements have been validated within SLAs (refer to Appendix G for additional information)	R	I	A	R		A/R	R	I
	SUS.IAMS.4.2.5.3	Technology Platform Owners must identify users whose access rights entitlements violate the SoD rules and review with supervisors. Any violations must be either remediated	R	I	A	R		A/R	R	I



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
		or documented, risk-assessed, and formally approved within SLAs (Refer to Appendix G for additional information)								
Attestation and Certification Requirements - User Entitlement Reviews	SUS.IAMS.4.2.5.4	Manager UER Minimum Frequency by Application Inherent Risk	C	I	R	R		A	C	
	SUS.IAMS.4.2.5.5	UER Responsible Personnel	C	I	R	R		A	C	
	SUS.IAMS.4.2.5.6	Manager UER Requirements	C	I	R	R		A	C	
	SUS.IAMS.4.2.5.7	UER Outcomes	R	C	A/R	R		A	I	I
	SUS.IAMS.4.2.5.8	Baseline UER Process Requirements for Process Owners	R	C	A/R	R		C	I	I
Attestation and Certification Requirement	SUS.IAMS.4.2.5.9	Review of Privileged Access	C	I	A/R	R		A/R	C	I



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
	SUS.IAMS.4.2.5.10	Reviewing Privileges for Infrastructure Components	R	I	A	I		A/R	C	I
Attestation and Certification Requirements - Application Certification	SUS.IAMS.4.2.5.11	Application Certification Frequency	R	R	A	I		C	C	I
	SUS.IAMS.4.2.5.12	Application coverage for non-person accounts	I	I	A/R	I		C	C	I
	SUS.IAMS.4.2.5.13	Pre-Certification Validation	I	I	A/R	C		R	C	I
	SUS.IAMS.4.2.5.14	Names and Business Description Requirements	I	I	A	R			I	R
	SUS.IAMS.4.2.5.15	Application Certification Outcomes	R	C	A	R		A/R		C

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
Attestation and Certification Requirements - Default Privileged Roles Certification	SUS.IAMS.4.2.5.16	Overall Objectives and Responsibilities	R	C	A	C		A/R	C	I
	SUS.IAMS.4.2.5.17	Default Access Review Minimum Frequency	R	C	A	C			C	I
	SUS.IAMS.4.2.5.18	Documentation, Segregation, and Maintaining Up-to-Date Users	R	I	A	C		R	C	C
	SUS.IAMS.4.2.5.19	Minimum Recertification for Privileged Access on All Assets	C	I	A	C		C	C	I
	SUS.IAMS.4.2.5.20	Default System Account Controls	R	A	R	C		C	C	I
	SUS.IAMS.4.2.5.21	Privileged Access Review Outcomes	R	A	R	C		C	C	I
Access Logging and Monitoring Requirements	SUS.IAMS.4.2.6.1	General Access Logging	R	A	R	C		C	C	I
	SUS.IAMS.4.2.6.2	Privileged Access Logging	R	A	R	C		C	C	I

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
Role Management and Separation of Duties (SoD)	SUS.IAMS.4.2.7.1	Managing Complex Entitlements	C	A	C	R			C	R
	SUS.IAMS.4.2.7.2	Role Management Process	C	I	C	A/R			C	R
	SUS.IAMS.4.2.7.3	Role Certification	R	I	A	R			C	R
	SUS.IAMS.4.2.7.4	Business Risk Identification	I	I	A	R			C	R
	SUS.IAMS.4.2.7.5	Policy Violation (Separation of Duty (SoD) and Toxic combination) Requirements	R	R	A	R			C	R
	SUS.IAMS.4.2.7.6	In the Santander US Public Cloud landing zone, role owners must certify, on at least an annual basis, the correctness of entitlements assigned to a role (for both application and business roles).	R	R	A	C			I	C

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
	SUS.IAMS.4.2.7.7	In the Santander US Public Cloud landing zone, access to development, test, pre-production, and production must be segregated.	R	R	A	A			C	I
Access Management Automation Requirements	SUS.IAMS.4.2.8.1	All information assets must be integrated with an IAMS approved by the s-CISO for the processes of identification, authentication, provisioning, and de-provisioning of user access rights entitlements	R	R	A	C		C	C	C
	SUS.IAMS.4.2.8.2	All privileged account to information assets must be integrated with a Privileged Access Management System ("PAMS") for the purposes of authentication of privileged user and sign-off on infrastructure assets	R	R	A	C		C	C	C
	SUS.IAMS.4.2.8.3	All privileged accesses must comply with IAM requirements regardless of their level of integration with the PAMS. For non-integrated assets,	R	R	A	A/R		C	C	C



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Req. ID	Requirements	Roles / Teams							
			Identity and Access Management	Application Administrator	Application IT Owner	Application Business Owner	Human Resources (HR)	Managers	Technology Platform Owner	Role Owner
		the Application Business Owner must define a plan to complete PAM integration								

8.7 Appendix G – SLA Matrix

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
Access Provisioning Requirements	SUS.IAMS.4.2 .1.1	Account Management Process	Termination (Application)	Revoking access from application for CUSO Employees	Revoking access from application	30 business days
			De-provisioning (Mover), IAM	Updates to Access Rights	Change in job	30 business days
	SUS.IAMS.4.2 .1.2	Third Parties and Non-Employees	Termination (Application)	Revoking access from application	Revoking access from application	Ongoing

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2 .1.3	Background Checks, Confidentiality Agreements, and Non-Disclosure Agreements ("NDAs")	Background Checks	Background review	Prior to granting access to workforce members who perform security-related functions or who are granted highly privileged access, a background and reference check must be performed	Ongoing
	SUS.IAMS.4.2 .1.4	On-boarding Procedures	Role Based Access control	Birthright access	As new personnel join the organization, basic access rights entitlements must be granted based on their role	Ongoing
	SUS.IAMS.4.2 .1.6	Temporary Access	Break Glass Access	Manual review	Break glass access must be approved by s-CISO or Chief Information Officer ("CIO") Infrastructure or delegate through a ticket request or incident ticket.	Ongoing

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2 .1.7	Remote Access			Access to applications/systems hosted outside the Bank network must have proper controls to ensure access is managed per defined Service Level Agreement. See also SUS.PCS Santander US Public Cloud Standard	Ongoing
Access Change (Mover / Transfer) Management Requirements	SUS.IAMS.4.2 .2.1	Updates to Access Rights	Access Rights Updates	Updates to Access Rights	Updating access rights due to transfers and changes in job functions after review	30 days
	SUS.IAMS.4.2 .2.2	Reporting of Movers	Privileged Access change reporting to HR	Reporting to HR	Managers (or approved delegates) must report any movers for external and internal movers to the User System of Record.	Immediate



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
			Privileged Access change reporting to HR	Reporting to Information Security team	HR must report any movers for external and internal movers to the Information Security team via the HR System.	Immediate
Ongoing Access Control Requirements	SUS.IAMS.4.2 .3.1	Inactive Accounts	Disablement of inactive accounts	Disablement of inactive accounts	Inactive accounts	90 calendar days
	SUS.IAMS.4.2 .3.2	Documentation, Segregation, and Maintaining Up-to-Date Users	Technology Platform Owners must identify users whose access rights violate the Separation of Duty ("SoD") rules	Manual	Any exceptions must be documented, risk-assessed, and formally approved	30 business days
	SUS.IAMS.4.2 .3.3	Privileged Access Change Intimation	N/A	N/A	N/A	Ongoing
	SUS.IAMS.4.2 .3.4	Privileged Access Change	N/A	N/A	N/A	Ongoing

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2 .3.5	Privileged Access Change Formalization	Privileged Access change reporting to HR	Reporting to HR	Managers (or approved delegates) must inform the HR team of any changes in functional roles of internal privileged users within 90 calendar days	90 calendar days
			Privileged Access change reporting to HR	Reporting to HR	Managers (or approved delegates) must report immediately to HR any movers or leavers for external users	Immediate
	SUS.IAMS.4.2 .3.6	Application Information/Ownership/Administration Change Formalization	Application Change Notification	Notification to IT Stewards & SanIAM	Application Owners and Administrators must inform Application IT stewards of any changes in the ownership, administration to be updated in Mega	90 calendar days

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2 .3.7	All human access to the operating system level on any compute service in the public cloud environment must be performed exclusively through an approved session manager.	Block network reachability accordingly with CUSO Public Cloud Standard	Technical	See CUSO Public Cloud Standard	Immediate
			On Cloud disable remote access services at OS level	Technical	See CUSO Public Cloud Standard	Immediate
			Enforce IAM-Controlled AWS SSM Access	Technical		Immediate
	SUS.IAMS.4.2 .3.8	There must be no nominal user account with privileged access rights. Any privileged user rights changes must be performed through PAMs. If this is not possible, an exception must be documented and approved by SEF annually.	Removal of nominal user privileged access rights.	Management	Security Exception Function Annual Approval of nominal users with privileged access rights	Annual
	SUS.IAMS.4.2 .3.9	Trained database administrators must monitor databases and maintain general awareness of normal operations,		Technical	DBAs must monitor databases.	Immediate / Continuous

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
		complementing the Information Security function. Users must be limited to only the data and information appropriate to their granted levels of access. Management must closely monitor database administrator activities as both a preventive and detective control, including access administration and data alterations.			Management must monitor activities of DBAs	
Access De-Provisioning (Leavers / Terminations) Requirements	SUS.IAMS.4.2 .4.1	Reporting of Leavers Privileged Access change reporting to HR	Privileged Access change reporting to HR	Reporting to HR	Managers (or approved delegates) must immediately report any leavers for external and internal leavers users to HR.	Immediate
			Privileged Access change reporting to HR	Reporting to Information Security team	HR must immediately report any external and internal leavers for both internal and external users to the	Immediate

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
					Information Security team.	
	SUS.IAMS.4.2.4.2	Revocation of Network ID Access for Terminated Users	Termination (Network)	AD/Network Access Revocation	Disable AD access which in turn revokes network access	1 business day
	SUS.IAMS.4.2.4.3	Privileged Access Revocation	Termination (Privileged Access Accounts) - local account cleanup	Privileged Access Accounts Revocation - local account cleanup	Disabling privileged access - local account cleanup	30 business days
Attestation and Certification Requirements	SUS.IAMS.4.2.5.1	The recertification process must be performed as a formal review of information assets to confirm that all granted access rights entitlements remain valid, updated, and in full compliance with the SoD rules and Principle of Least Privilege	Certification Requirements	Hybrid	The recertification process uses email or an on-line review application (e.g. SailPoint).	Ongoing
	SUS.IAMS.4.2.5.2	Technology Platform Owners must be held accountable for executing	Certification Requirements	Hybrid	The recertification process uses email or an on-line review	Ongoing



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
		the recertification for their information assets and collecting all recertification evidence that access rights entitlements have been validated within SLAs (refer to Appendix G for additional information)			application (e.g. SailPoint).	
	SUS.IAMS.4.2.5.3	Technology Platform Owners must identify users whose access rights entitlements violate the SoD rules and review with supervisors. Any violations must be either remediated or documented, risk-assessed, and formally approved within SLAs (Refer to Appendix G for additional information)	Certification Requirements	SOD Exception	Any violations must be either remediated or documented, risk-assessed, and formally approved within SLAs See also SUS.IAMS.4.2.5.18	30 business days

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
Attestation and Certification Requirements - User Entitlement Reviews	SUS.IAMS.4.2 .5.4	Manager UER Minimum Frequency by Application Inherent Risk	Certification Requirements	Hybrid	The recertification process uses email or an attestation and certification service according to SLA frequencies.	SOX: semi-annual GLBA: annual Other Risk Critical & High: Annual Other Risk: Moderate, Low & Very Low: Management Decision
	SUS.IAMS.4.2 .5.5	UER Responsible Personnel	Certification Requirements	Hybrid	Both managers and Application Owners must perform UERs for applications in the Identity and Access Management System ("IAMS").	Ongoing
	SUS.IAMS.4.2 .5.6	Manager and Application Owner UER Requirements	Regulatory Applications Manager UER in Identity and Access	Attest to access rights for all users with access to applications	All	Semi Annual



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
			Management System (IAMS)	categorized under SOX		
				GLBA	Critical	Annual
					High	Annual
					Moderate	Annual
					Low-	Annual
					Very Low	Annual
			Non-Regulatory Applications Manager UER	Other	Critical	Annual
					High	Annual
					Moderate	Management Discretion
					Low	Management Discretion
					Very Low	Management Discretion
			Manager UER based on	Attest to access rights for all users with	Restricted	Semi-Annual



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
			Application Classification	access to information assets classified as Restricted		
				Attest to access rights for all users with access to information assets classified as Confidential	Confidential	Semi-Annual
				Attest to access rights for all users with non-read- only rights	Internal	Annual
				Attest to access rights for all users with non-read- only rights	Public	Annual
			Manager UER for External Users	Attest to access rights for external users	Accounts Assigned to External Users	Annual
	SUS.IAMS.4.2 .5.22		Application Owner	Attest to management of access rights for all users	Applications in Identity Management Portal (IMP)	Annual

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2 .5.7	UER Outcomes	All Manager UER	Remedy UER outcomes	Revocation of access rights based on UER outcomes	30 business days after close of the recertification campaign
	SUS.IAMS.4.2 .5.8	Baseline UER Process Requirements for Process Owners	All Manager UER	Attestation and certification service	Each system or service account must be the responsibility of one workforce member.	Ongoing
Attestation and Certification Requirements - Privileged Access Review	SUS.IAMS.4.2 .5.9	Review of Privileged Access	Privileged Access Review	Privileged Access Review Frequency - All Regulatory Information Assets	Privileged Access Review Frequency - All Regulatory Information Assets	Annual
			Privileged Access Review	Privileged Access Certification for Regulatory Accounts Assigned to External Users	Privileged Access Certification for Regulatory Accounts Assigned to External Users	Annual
	SUS.IAMS.4.2 .5.10	Reviewing Privileges for Infrastructure Components	Infrastructure UER	UER Preparation and assignment	All privileged access generic accounts must be assigned to a supervisor responsible for controlling all the	Ongoing

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
					users with access permission to these accounts.	
Attestation and Certification Requirements - Application Certification	SUS.IAMS.4.2 .5.11	Application Certification Frequency	Application Certification	Application Owner Application Certification	Review general application details including application description, entitlements, and associated service accounts	Annual
	SUS.IAMS.4.2 .5.12	Application Certification Overall Coverage	Application Certification	Application Owner Application Certification	Associated service accounts must be maintained.	Ongoing
	SUS.IAMS.4.2 .5.13	Application Certification Reviews and Updates	Pre-Certification Validation	Manual Review	Accuracy and general business understandability must be reviewed and updated for the following elements: Application name Application description Entitlement names	Ongoing



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
					Entitlement business descriptions	
	SUS.IAMS.4.2 .5.14	Names and Business Description Requirements	Pre-Certification Validation	Manual Review	The application, associated entitlements, and service accounts must be evaluated to help confirm that names and business descriptions accurately and succinctly convey the information required by the reviewer	Ongoing
	SUS.IAMS.4.2 .5.15	Application Certification Outcomes	Pre-Certification Validation	Manual Review	Actions must be performed based on the review of the application and entitlement names and descriptions:	Annually or as required by the IAM team
Attestation and Certification Requirements - Privileged	SUS.IAMS.4.2 .5.16	Access Review Conduct	Recertification of access	Access review	IAM/PAM Team are accountable for executing and collecting all evidence that	Ongoing

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
					access rights have been validated.	
	SUS.IAMS.4.2 .5.17	Default Access Review Minimum Frequency	Provisioning (IAM/PAM Default Access)	Default Privileged Access	Review of the definition of Privilege access dictionary	Annually or if there is any significant change
	SUS.IAMS.4.2 .5.18	Documentation, Segregation, and Maintaining Up-to-Date Users	Provisioning (SOD)	SOD Exception	Review exception request for SOD on privilege users	30 business days
	SUS.IAMS.4.2 .5.19	Minimum Recertification for Privileged Access on All Regulatory Assets	Minimum Privileged Access review frequency	Minimum Privileged Access review frequency	Recertification of Privileged Access on all Regulatory assets	Semi-Annual
	SUS.IAMS.4.2 .5.20	Default System Account Controls	Exceptions for default Privileged accounts that cannot be locked	Exceptions for Privileged Access	Exceptions for privileged default accounts that cannot be locked	30 business days
	SUS.IAMS.4.2 .5.21	Privileged Access Review Outcomes	Privileged Access Review	Remedy Privileged Access Review outcomes	Revocation of privileged access rights based on UER outcomes	30 business days

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
Access Logging and Monitoring Requirements	SUS.IAMS.4.2 .6.1	General Access Logging	Access Logging and Monitoring	Manual	Security logs must be retained for at least two (2) years, with a minimum of three (3) months immediately available for analysis.	Retention: 2 years On-line: 3 months
	SUS.IAMS.4.2 .6.2	Privileged Access Logging	Access Logging and Monitoring	Manual	Alerts must be operational and monitored 24x7 Security logs must be retained for at least two (2) years, with a minimum of three (3) months immediately available for analysis.	Retention: 2 years On-line: 3 months
Role Management and Separation of Duties (SoD)	SUS.IAMS.4.2 .7.1	Managing Complex Entitlements	Role Management - Provisioning	Manual	Combining multiple entitlements into a role that can be used to simplify the access request, access provisioning, and access attestation processes must be	N/A

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
					considered for applications with complex entitlements.	
	SUS.IAMS.4.2 .7.2	Role Management Process	Role Management - Provisioning		A process for designing, implementing, assigning, and reviewing roles and associated entitlements and SoD must be developed when roles are used.	N/A
	SUS.IAMS.4.2 .7.3	Role Certification	Recertification (App Role SOD)	Recertify application entitlement with application/business owner	Recertify application with application/business owner	Annually or if there is any significant change
	SUS.IAMS.4.2 .7.4	Business Risk Identification	Risk management	Manual	Business (and/or operational) risks associated with roles / entitlement combinations must be identified as part of the role management process for business applications	Ongoing



CUSO Identity and Access Management Standard

Date Last Approved: 07.28.2026

Version Number 11.0

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
	SUS.IAMS.4.2.7.5	Policy Violation (Separation of Duty (SoD) and Toxic combination) Requirements	Recertification (App SOD)	Recertify SOD rule with application/business owner	Recertify SOD rule with application/business owner	Annually or if there is any significant change
	SUS.IAMS.4.2.7.6	In the Santander US Public Cloud landing zone, role owners must certify, on at least an annual basis, the correctness of entitlements assigned to a role (for both application and business roles).	Recertification (Annual Role Review)	Recertify application entitlement with application/business owner	Recertify application with application/business owner	Annually or if there is any significant change
	SUS.IAMS.4.2.7.7	In the Santander US Public Cloud landing zone, access to development, test, pre-production, and production must be segregated.	Recertification (Roles are requested at the account level)	Recertify application entitlement with application/business owner	Recertify application entitlement with application/business owner	Quarterly / Semi-annually or Annually

Area	Requirement ID	Requirement	Control	Review Type	Detail	SLA
Access Management Automation Requirements	SUS.IAMS.4.2 .8.1	All information assets must be integrated with an IAMS approved by the s-CISO for the processes of identification, authentication, provisioning, and de-provisioning of user access rights entitlements	Access Management	Automation	IAMS for the processes of identification, authentication, provisioning, and de-provisioning of user access rights entitlements	Ongoing
	SUS.IAMS.4.2 .8.2	All privileged account to information assets must be integrated with a Privileged Access Management System ("PAMS") for the purposes of authentication of privileged user and sign-off on infrastructure assets	Access Management	Automation	Privileged Access Management System ("PAMS") for the purposes of authentication of privileged user and sign-off on infrastructure assets	Ongoing
	SUS.IAMS.4.2 .8.3	All privileged accesses must comply with IAM requirements regardless of their level of integration with the PAMS. For non-integrated assets, the Application Business Owner must define a plan to complete PAM integration	Access Management	Automation	All privileged accesses must comply with IAM requirements	Ongoing